TEAM CODEBASE LOOPS · ANGELHACK “BUILDING WITH IBM BOB”

AgentGuard: guardrails for AI agents, enforced by default

AI agents act — they call tools, move files, hit APIs. Nobody checks whether they’re allowed to. AgentGuard is the checkpoint every agent tool call must pass.

Juan Serrano · github.com/022UGDW213/agentguard-ibm-bob

THE PROBLEM

The confused deputy

Agents are the new attack surface.

- An agent tricked by a malicious prompt, a poisoned tool description, or a compromised plugin will happily read `/etc/passwd` or exfiltrate keys — *with your credentials*.
- Red-team / blue-team tooling was built for humans, not for software acting at machine speed.
- Your agent is a deputy with your keys. Anyone who confuses it *becomes* you.

THIS MONTH IN THE REAL WORLD

`CVE-2026-90970` (CVSS 9.9, disclosed Oct 2): a crafted flow config escaped GitLab's AI Gateway prompt-template sandbox → arbitrary commands on the gateway host. Fixed in 19.2.4 / 19.3.2 / 19.4.1. Agent infrastructure is already the target.

THE SOLUTION

Deny by default

Policy engine

Explicit rules sit in front of every tool call. Anything unmatched is denied — deny rules beat allow rules.

Capability tokens

Authorization travels as HMAC-signed, narrowly-scoped, expiring tokens bound to the agent. No token, no scope, no call.

Audit ledger

Every decision — allow or deny — lands in an append-only ledger with the reason. Proof of what your agents tried to do.

This is the confused-deputy fix, and it works with any model.

DESIGN

Model-agnostic by design

- The harness wraps a `ModelBackend` interface — the same choke point governs local tools, a Bob-driven loop, or any future model.
- Secure-codebase scanner: secret patterns plus live `pip-audit` / `npm audit` — audit is clean, zero known vulnerabilities.
- Zero-dependency `Java SDK` with the same HMAC tokens (interop proven both ways) + a `JSON module` for policies, tokens, audit entries.
- No stubs, no simulated findings — every component runs for real.

We don’t care which model you use. The guardrail is the same.

BUILT WITH IBM BOB

Integration, two directions

Bob → AgentGuard

A real MCP server (`check_policy`, `scan_codebase`, `audit_summary`) on the official MCP SDK; `.bob/mcp.json` auto-wires it into Bob IDE. Bob reads the codebase and *generates* the security policies.

AgentGuard → Bob

`BobShellBackend` drives Bob headlessly via the Bob Shell CLI — a Bob-powered agent loop under the same policy engine. Bob *authored the test suite*: 90 tests passing, 4 skipped.

Honest note: IBM publishes no public REST API for Bob — CLI + MCP are the verified surfaces, and we built on exactly those. We read the docs; we didn’t invent endpoints.

LIVE DEMO

Watch the DENY land

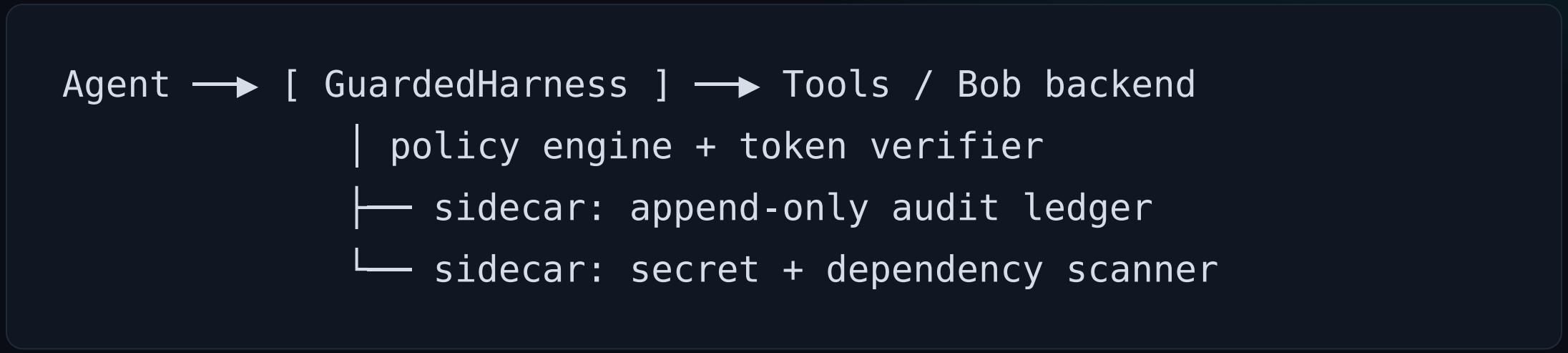
agentguard-demo.o22ugdw213.network — one-click guest login, no signup.

```
read_file welcome.txt → ALLOW · legitimate call, valid token
read_file /etc/passwd → DENY · path escapes the sandbox
run_command → DENY · never heard of it — denied by default
trap read_file /etc/passwd → DENY · fingerprinted sandbox_escape, policy drafted
```

Plus a **Skills API** try-it console — seven live skills including `trap`. Attack it yourself: the trap fingerprints every attempt and drafts the policy that stops its whole class. Every attack makes the guard stronger.

ARCHITECTURE

One choke point



Deny rules beat allow rules; unmatched calls die. One choke point — that’s the entire security model.

PROOF IT WORKS

90 tests pass · 4 skipped

- The 4 skips need a real Bob API key — they skip cleanly, never fake a result.
- Cross-language token tests: Java-minted tokens verify in Python and vice versa.
- `pip-audit` clean — zero known vulnerabilities; Dockerized, no mocks, no stubs.
- Red-team replay: 76 attack variants fired at the live demo — 74 denied, **0 allowed**.
- CLI verified end to end: allowed calls succeed, `/etc/passwd` denied, audit shows 2 allow / 1 deny.

A security tool you can’t test is a rumor. Ours has 90 passing tests.

WHAT'S NEXT

This is a beginning

- Ship the audit ledger to tamper-evident storage.
- Per-team policy packs and a hosted policy API.
- Deeper Bob IDE workflows — pre-tool-call hooks inside Bob's own loop.
- Long-term: the all-in-one agent security platform — beyond red-team / blue-team.

The hackathon project is the first module of the company.

THE ASK

Agents are acting in production today. Give them guardrails.

Team CodeBase Loops · Juan Serrano

github.com/022UGDW213/agentguard-ibm-bob · agentguard-demo.o22ugdw213.network